



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2023-5678 Excessive time spent in DH check / generation with large Q parameter value

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-13
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2023-5678 Excessive time spent in DH check / generation with large Q parameter value - Vulnerability Report

Published: 2026-06-13 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

`CVE-2023-5678` is an OpenSSL denial-of-service weakness affecting X9.42 Diffie-Hellman key generation and public-key or parameter validation when unusually large `Q` values are supplied. Public source material reviewed for this report aligns that applications calling `DH\_generate\_key()`, `DH\_check\_pub\_key()`, `DH\_check\_pub\_key\_ex()`, `EVP\_PKEY\_public\_check()`, or `EVP\_PKEY\_generate()` may spend excessive time processing attacker-influenced input, creating a resource-consumption and service-delay condition.

The operational risk is narrower than a generic "OpenSSL remote compromise" headline. OpenSSL states that the SSL/TLS implementation is not affected, and the issue only becomes reachable when an application or operational workflow exposes these specific DH-generation or DH-validation paths to untrusted keys or parameters. In practice, the most exposed environments are custom cryptographic services, certificate or key-validation utilities, multi-tenant onboarding or PKI tooling, and automation that uses `openssl pkey -pubcheck` or `openssl genpkey` on externally supplied material.

For defenders, the immediate priority is to identify where OpenSSL is being used beyond ordinary TLS handshakes. Organizations that only rely on OpenSSL for routine SSL/TLS server or client operations should treat this as a low-urgency dependency issue. Organizations that parse attacker-supplied X9.42 DH material, expose crypto-validation APIs, or run backend processing of untrusted key material should prioritize upgrades, input controls, timeout protections, and hunting for unusually long crypto-processing events.

Public reporting reviewed for this assessment did not provide authoritative evidence of in-the-wild exploitation, KEV inclusion, or named threat-actor use. The strongest current judgment is that `CVE-2023-5678` is a practical denial-of-service concern for niche but real workflows, with lower urgency for general-purpose TLS-only estates and higher urgency for services that validate or generate DH material from untrusted sources.

2. Intelligence Requirement

This report addresses the following intelligence requirement: what does `CVE-2023-5678` mean for defenders using OpenSSL, which real-world workflows are materially exposed, how should the scoring and severity divergence be interpreted, and what remediation, detection, and hunting actions should teams prioritize?

Question	Assessment
What is the flaw?	Excessive processing time during X9.42 DH key generation or validation when very large `Q` values are supplied.
Which functions matter?	`DH_generate_key()`, `DH_check_pub_key()`, `DH_check_pub_key_ex()`, `EVP_PKEY_public_check()`, and `EVP_PKEY_generate()`; OpenSSL CLI `pkey -pubcheck` and `genpkey` are also affected.
Is ordinary OpenSSL SSL/TLS traffic affected?	No. Reviewed upstream material explicitly states the OpenSSL SSL/TLS implementation is not affected.
What is the likely impact?	Denial of service, request stalls, worker exhaustion, or long-running backend jobs where untrusted DH parameters or keys are processed.
Which versions are affected?	OpenSSL `1.0.2` before `1.0.2zj`, `1.1.1` before `1.1.1x`, `3.0.0` through `3.0.12`, and `3.1.0` through `3.1.4` per CNA/NVD tracking.
Is there severity disagreement?	Yes. OpenSSL rates the issue `Low`, while Ubuntu/Oracle/NVD track `CVSS 5.3 Medium`, and GitHub advisory data shows a `7.5 High` availability-heavy score.
Is exploitation confirmed in the wild?	No reviewed authoritative source confirmed active exploitation or

	KEV inclusion at review time.
What matters most to defenders?	Inventory non-TLS OpenSSL usage, patch exposed branches, add timeout and resource controls around DH validation or generation workflows, and hunt for abnormal long-running crypto operations.

3. Source Review and Confidence

Source	Contribution	Confidence
OpenSSL security advisory `20231106.txt`	Canonical issue summary, impact framing, explicit statement that SSL/TLS is not affected, and branch-level remediation context.	High
OpenSSL CNA JSON / NVD record	Affected version ranges, NVD-enriched CVSS data, CWE tagging, and consolidated references.	High
GitHub advisory `GHSA-2cj7-mg3x-9mhq`	Additional ecosystem reference, alternate CVSS representation, and commit links.	High
Debian security tracker	Distribution package-fix context and explicit vulnerable/fixed package records for Debian branches.	High
Ubuntu CVE page	Ubuntu priority, CVSS interpretation, and package-status examples across supported releases.	Medium
Oracle Linux CVE page	Downstream enterprise-Linux impact framing and errata references.	Medium
Microsoft Security Update Guide entry	Intake trigger and tracking confirmation only; not treated as the canonical technical source for this OpenSSL issue.	Medium

Confidence is high for the core technical conclusions: the flaw is real, it centers on oversized X9.42 DH `Q` handling, it can produce denial-of-service conditions where untrusted input reaches affected APIs, and ordinary OpenSSL SSL/TLS operations are explicitly out of scope. Confidence is medium for real-world exploit prevalence because the reviewed public record does not include authoritative campaign reporting, a KEV listing, or widely cited incident response casework showing exploitation at scale.

A second confidence caveat is severity normalization. Upstream OpenSSL rates the issue as `Low`, reflecting the narrow reachability and non-TLS scope. Other trackers publish medium or higher CVSS values because the theoretical network-facing impact can still be availability-relevant when applications expose these code paths. Defenders should therefore prioritize based on workflow exposure rather than on a single score alone.

4.1 Vulnerability Metadata

Field	Value
CVE	`CVE-2023-5678`
Product / component	OpenSSL X9.42 Diffie-Hellman key generation and public-key / parameter validation paths
Vulnerability class	Excessive processing time leading to denial of service from

	oversized `Q` input
Primary affected functions	`DH_generate_key()`, `DH_check_pub_key()`, `DH_check_pub_key_ex()`, `EVP_PKEY_public_check()`, `EVP_PKEY_generate()`
Additional affected tooling	OpenSSL CLI `pkey -pubcheck` and `genpkey`
Not affected	OpenSSL SSL/TLS implementation; OpenSSL `3.0` and `3.1` FIPS providers
Upstream severity	`Low` per OpenSSL advisory
NVD-enriched severity	`CVSS 3.1 5.3 Medium` with `AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L`
Alternate advisory severity	GitHub advisory data reflects `CVSS 7.5 High` availability-heavy scoring
CNA/NVD affected versions	`1.0.2` before `1.0.2zj`; `1.1.1` before `1.1.1x`; `3.0.0`-`3.0.12`; `3.1.0`-`3.1.4`
Public disclosure	`2023-11-06` in OpenSSL/CVE publication records
Exploitation status at review time	No authoritative confirmation of in-the-wild exploitation found

4.2 Flaw Mechanics

The vulnerability stems from incomplete handling of unusually large X9.42 DH parameters. Reviewed upstream descriptions state that `DH\_check()` already performs the necessary checks after `CVE-2023-3817`, but `DH\_check\_pub\_key()` does not perform those same protections for excessively large `P` and `Q` values. Similarly, `DH\_generate\_key()` checks for an excessively large `P` but does not check for an excessively large `Q`.

That distinction matters because applications may assume these APIs are safe to use on externally supplied cryptographic material. When a service, backend worker, or administrative utility accepts attacker-controlled DH keys or parameters and passes them into the affected functions, processing can become extremely slow and tie up CPU or worker capacity. The likely impact is degraded availability rather than code execution, data theft, or cryptographic compromise.

4.3 Exposure Profile

Exposure pattern	Why it matters	Priority
Custom service validates attacker-supplied X9.42 DH public keys or parameters	Directly reaches the vulnerable validation path and may allow remote request-based worker exhaustion	Immediate
PKI, onboarding, or cryptographic automation ingests untrusted DH material	Backend jobs can stall or queue, producing operational denial of service	Immediate
OpenSSL CLI `pkey -pubcheck` or `genpkey` run on files from external parties	Analysts, CI, or batch jobs may experience long runtimes and service delay	High
Multi-tenant key-management or developer self-service portals	A low-complexity request may consume disproportionate compute and affect other tenants	High

General-purpose TLS servers and clients using OpenSSL only for SSL/TLS handshakes	Upstream explicitly states SSL/TLS implementation is not affected	Reduced
Branches with vendor backports but non-obvious version strings	String-only version checks may miss downstream fixes or package-specific remediation	Medium

4.4 Representative Attack Scenarios

Scenario	Description	Defensive meaning
Crypto-validation API abuse	An internet-facing or partner-facing service accepts DH parameters or public keys from users and validates them with <code>`DH_check_pub_key()`</code> or related APIs, causing long request handling times	Patch and wrap exposed validation paths with strict input limits and timeouts
Backend queue starvation	A certificate, key-import, or onboarding workflow processes attacker-supplied X9.42 material in asynchronous workers, slowing or blocking legitimate work	Review queue depth, worker timeouts, and crypto-processing telemetry
Tooling abuse against operations teams	An attacker or untrusted partner supplies a crafted key file that an analyst or automation pipeline checks with <code>`openssl pkey -pubcheck`</code> or uses in <code>`genpkey`</code> workflows	Treat external crypto artifacts like untrusted files and isolate validation workflows
Shared-service tenant degradation	In a multi-tenant platform, one tenant repeatedly submits pathological DH input, consuming disproportionate compute and impacting other tenants	Apply rate limits, admission control, and per-tenant resource isolation

4.5 MITRE ATT&CK Mapping

ATT&CK ID	Technique	Rationale
`T1499`	Endpoint Denial of Service	Best-fit mapping when attacker-supplied DH material causes prolonged processing and reduces service availability.
`T1499.004`	Application or System Exploitation	Applicable when the weakness is abused through an exposed application workflow that performs DH validation or generation on untrusted input.

5. Threat Context

`CVE-2023-5678` is best understood as a niche but defensible availability issue in application-layer cryptographic workflows, not as a broad OpenSSL internet emergency. The public record reviewed for this report repeatedly emphasizes that SSL/TLS handshakes themselves are not affected. That sharply narrows the victim set compared with common assumptions about OpenSSL flaws.

The environments that should care most are those where OpenSSL is embedded in custom services or tooling that accept untrusted cryptographic material. Examples include certificate-management portals, hardware or software onboarding systems, developer self-service platforms, multi-tenant crypto services, and operational scripts that validate externally sourced DH keys

or parameters. In those environments, a remote actor may be able to induce long-running operations that reduce throughput, trigger timeouts, or exhaust worker pools.

The public exploit picture remains limited. This review did not find authoritative evidence of CISA KEV inclusion, named threat-actor use, or confirmed widespread exploitation. That lowers the urgency relative to broadly weaponized remote code execution flaws. However, this should not be dismissed outright: attackers do not need code execution here to create meaningful operational pain if an exposed workflow allows repeated submission of pathological DH material.

The severity divergence across trackers is analytically important. OpenSSL's `Low` rating reflects the narrow reachability and the fact that common SSL/TLS usage is unaffected. Medium or high CVSS variants reflect that network-reachable availability degradation is still possible where vulnerable APIs are exposed. Defenders should therefore prioritize based on actual application architecture and trust boundaries instead of choosing whichever single severity label sounds most dramatic.

6. Detection and Hunting

Detection for `CVE-2023-5678` should emphasize exposure discovery and anomalous processing behavior rather than signature-style IOCs. Reviewed public sources did not provide stable domains, hashes, or exploit artifacts. The strongest analytic approach is to identify where OpenSSL's affected DH functions are reachable from untrusted input, then monitor for long-running validation or generation activity, repeated failures, and suspicious use of OpenSSL CLI validation commands.

6.1 Detection Coverage Summary

Signal	Telemetry source	Analytic goal	Coverage caveat
OpenSSL versions in vulnerable ranges	SBOM, package inventory, container scanning, software inventory	Identify systems requiring remediation	Version-only checks may miss vendor backports
Source code or binaries referencing affected DH APIs	SAST, code search, symbol search, dependency analysis	Find applications that use risky non-TLS DH workflows	Requires application inventory, not just package inventory
Long-running requests or jobs tied to key validation, import, or onboarding endpoints	APM, web logs, worker metrics, job telemetry	Detect exploitation attempts or operational degradation	Needs endpoint naming or business-context mapping
`openssl pkey -pubcheck` or `openssl genpkey` on untrusted files	EDR process telemetry, shell history, CI logs	Surface analyst or automation exposure to crafted artifacts	Benign admin use can be noisy without context
CPU spikes or worker exhaustion correlated with DH-processing services	Host metrics, orchestrator telemetry, service dashboards	Spot resource-consumption abuse	Low specificity without workflow context

6.2 Example KQL Hunt Query

This query is tuned for Microsoft Defender or similarly normalized endpoint telemetry. It hunts for suspicious OpenSSL CLI validation or generation activity and highlights long or unusual command lines. Field names may need adaptation for the local schema.

```
let lookback = 30d;
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where FileName =~ "openssl"
| where ProcessCommandLine has_any ("pkey -pubcheck", "genpkey", "DH_check_pub_key",
"EVP_PKEY_public_check")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName, InitiatingProcessCommandLine, FolderPath
| order by Timestamp desc
```

6.3 Example Splunk Hunt Query

This query is intended for application, CI, or Linux process telemetry where OpenSSL command execution and service-delay indicators are collected.

```
(index=linux OR index=ci OR index=app)
("openssl" AND ("pkey -pubcheck" OR "genpkey" OR "DH_check_pub_key" OR "EVP_PKEY_public_check"))
| stats earliest(_time) as first_seen latest(_time) as last_seen count values(host) as host
values(user) as user values(process) as process values(command) as command by sourcetype
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

6.4 Threat-Hunting Questions

- Which applications expose OpenSSL-backed DH validation or generation to external users, tenants, customers, or imported third-party material?
- Which repositories, containers, or packages still ship OpenSSL versions in the affected ranges, and do any rely on legacy `1.0.2` or `1.1.1` branches with premium-support or vendor-backported fixes?
- Have any certificate-import, crypto-validation, or onboarding endpoints shown unexplained latency spikes, timeouts, queue growth, or worker exhaustion since the 2023 disclosure window?
- Are analysts, CI systems, or automation pipelines running `openssl pkey -pubcheck` or `genpkey` on externally sourced files without sandboxing or runtime limits?
- Do service owners incorrectly assume they are exposed simply because OpenSSL is installed, even when their workflows never touch the vulnerable DH code paths?

No stable IOC set was identified from reviewed public sources. This is a detection-and-hunting problem centered on exposure analysis, unusual process behavior, and performance anomalies rather than on hashes, domains, or network indicators.

7. Recommendations

Priority	Owner	Action	Rationale
Immediate	Application / platform engineering	Inventory every service, job, script, or tool that uses OpenSSL for DH key generation or validation beyond routine SSL/TLS operations	Exposure depends on workflow reachability, not just package presence
Immediate	Application / crypto engineering	Upgrade affected OpenSSL branches to fixed or vendor-backported builds aligned with `1.0.2zj`, `1.1.1x`, `3.0.13`, and `3.1.5` tracking guidance	Removes the vulnerable processing path where updates are available
Immediate	Service owners	Add strict input-size validation, request timeouts, and resource quotas around untrusted DH-processing workflows	Limits denial-of-service impact even before full patching
High	SOC / detection engineering	Add hunts for `openssl pkey -pubcheck`, `genpkey`, long-running crypto-validation jobs, and request-latency spikes on key-processing services	Best available runtime visibility for this CVE
High	DevSecOps / SCA	Search source code and SBOMs for `DH_generate_key`, `DH_check_pub_key`, `DH_check_pub_key_ex`, `EVP_PKEY_public_check`,	Package inventory alone does not prove exploitability

		and `EVP_PKEY_generate` usage	
Medium	Operations / CI owners	Isolate or sandbox validation of externally supplied cryptographic artifacts used in automation, partner onboarding, or analyst workflows	Reduces blast radius from crafted files
Medium	Vulnerability management	Track distro-specific package status for Debian, Ubuntu, Oracle Linux, and other vendor branches rather than relying only on upstream version strings	Downstream backports and support branches can obscure remediation state
Low	Threat intelligence	Monitor for proof-of-concept publication, KEV inclusion, or new exploitation reporting that would justify raising priority	Public exploit maturity was limited at review time

Additional analyst guidance:

- Do not over-prioritize this CVE solely because OpenSSL is widely deployed; the decisive question is whether untrusted input can reach the affected DH code paths.
- Do not under-prioritize it in certificate-management, onboarding, or cryptographic middleware services where attacker-controlled key material is routine.
- Where patching cannot happen immediately, enforce concurrency controls and request budgets so a small number of malicious submissions cannot monopolize worker capacity.

8. References

- 1. OpenSSL Security Advisory 2023-11-06: <https://www.openssl.org/news/secadv/20231106.txt>
- 2. Microsoft Security Update Guide: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2023-5678>
- 3. NVD detail page: <https://nvd.nist.gov/vuln/detail/CVE-2023-5678>
- 4. OpenSSL CNA JSON record: <https://openssl-library.org/news/secjson/cve-2023-5678.json>
- 5. GitHub advisory `GHSA-2cj7-mg3x-9mhq`: <https://github.com/advisories/GHSA-2cj7-mg3x-9mhq>
- 6. Debian security tracker: <https://security-tracker.debian.org/tracker/CVE-2023-5678>
- 7. Ubuntu CVE page: <https://ubuntu.com/security/CVE-2023-5678>
- 8. Oracle Linux CVE page: <https://linux.oracle.com/cve/CVE-2023-5678.html>